Планировщик отпусков

КОРПОРАТИВНЫЙ ГРАФИК ОТПУСКОВ И СОГЛАСОВАНИЙ

Заметки к выпуску 1.0.0

Что изменится для сотрудников, кадровой службы и администратора · версия 1.0.0

30 октября 2026

© Alexander Yurasov

Содержание

1 О документе 3

2 Коротко 4

3 Что увидят сотрудники 5

4 Что изменится для кадровой службы 6

5 Что сделать администратору при обновлении 7

6 Безопасность 8

7 Известные ограничения 9

1 О документе

Заметки к выпуску «Планировщика отпусков» 1.0.0 — первому выпуску, готовому к промышленной эксплуатации и к подаче в единый реестр российских программ. Для кого: кадровая служба, служба ИБ, администраторы стенда. Полный список изменений — `CHANGELOG.md`, порядок обновления — регламент `docs/runbooks/update.md`.

2 Коротко

- **Проверено на организации в 2000 сотрудников:** один виртуальный процессор обслуживает рабочий день в разгар кампании планирования и утренний вход всей организации за 15 минут; рекомендуемые 2 vCPU выдерживают восьмикратную нагрузку часа пик. Проверены пики кампании, отказы под нагрузкой, многочасовая непрерывная работа и рост данных за 5 лет (`docs/performance/report-v1.0.0.md`).
- **Принято службой ИБ по самооценке:** каждая операция API проверена каждой ролью (465 проверок), 14 найденных недостатков исправлены до выпуска, оценка по OWASP ASVS уровня 1 и пакет для внешнего теста на проникновение (`docs/security/assessment-v1.0.0.md`).
- **Готово к приёмке кадровой службой:** программа и методика испытаний на 66 испытаний и протокол для подписи (`docs/acceptance/`).
- **Готово к подаче в реестр:** девять документов комплекта, уведомления о лицензиях из SBOM, дистрибутив с контрольными суммами (`docs/registry/` , `scripts/build-dist.sh`).
- **Готово к эксплуатации:** регламенты обновления, резервного копирования, переключения на реплику, действий по каждому оповещению и разбора инцидента (`docs/runbooks/`).

3 Что увидят сотрудники

- График отпусков обновляется сам после изменений коллег, как и раньше, но открытые вкладки больше не перегружают сервер одновременным перечитыванием — график открывается быстрее в часы пик.
- Сотрудник получает уведомление (и письмо, если включены), когда его пароль изменён или кадровая служба выдала новый: так он сразу узнаёт о чужой смене пароля.
- В подборе заместителя и в списках коллег видны ФИО, должность и отдел; логин, почта, нормы дней и табельный номер коллеги — только ему самому, его руководителю и кадровой службе.
- При ошибке сервера сообщение содержит «Код запроса» — по нему администратор находит запрос в журналах.
- Сотрудника больше не выбрасывает на экран входа без причины: раньше это изредка случалось при открытии новой вкладки в часы пик, а также при перегрузке или перезапуске сервера. Теперь при перегрузке появляется сообщение «повторите через несколько секунд», а сеанс сохраняется.

4 Что изменится для кадровой службы

- Выгрузка формы Т-7 на всю организацию больше не задерживает работу остальных сотрудников.
- Приглашение кампании планирования доходит письмом до всей организации за минуты, а не за полчаса.
- Открытие кампании, напоминание и утверждение графика больше не замедляют работу остальных: уведомление всей организации не вызывает одновременных запросов из всех открытых вкладок.
- В выгрузке графика отпусков даты начала и окончания — настоящие даты Excel в формате ДД.ММ.ГГГГ: их можно сортировать и фильтровать по периоду.
- Неверный старый пароль при смене пароля считается неудачной попыткой входа: после порога учётная запись блокируется, как при подборе пароля.

5 Что сделать администратору при обновлении

Подробно — `docs/runbooks/update.md`, раздел «Особые шаги 1.0.0». Главное:

ИЗМЕНЕНИЕ	ДЕЙСТВИЕ
`JWT_SECRET` обязателен: значения по умолчанию в `docker-compose.yml` больше нет	Проверьте, что в `.env` задан секрет не короче 32 символов; без него `docker compose` не выполнит ни одной команды
PostgreSQL опубликован только на `127.0.0.1:5432`	Внешним системам, которые подключались к базе напрямую, нужен доступ с узла стенда или SSH-туннель
Сервисы перезапускаются сами (`restart: unless-stopped`)	Ничего; после перезагрузки узла стенд поднимается без участия администратора
Остановка `server` закрывает потоки событий сразу	Ничего; перезапуск и обновление `server` занимают секунды: раньше остановка ждала 10 с и завершалась принудительно
`DB_POOL_SIZE`, `TRUST_PROXY`, `EVENTS_POLL_MS` из `.env` теперь действуют	Проверьте эти строки в `.env` — раньше они не доходили до сервера
Образы на Node.js 22 LTS, имена образов с версией (`VP_VERSION`)	Для установки без интернета — дистрибутив (`scripts/build-dist.sh`): `docker load`, `VP_VERSION=1.0.0` в `.env`
Ежедневная задача сроков хранения	Удаляет истёкшие сеансы, письма старше 90 дней и прочитанные уведомления старше года; документы кадрового учёта и журнал изменений не удаляются
Журнал сервера — строки JSON с кодом запроса	Сборщику журналов организации — разбор JSON; переменные `LOG_FORMAT`, `REQUEST_LOG`, `SLOW_REQUEST_MS`, `SLOW_QUERY_MS`, `PG_SLOW_MS`

Миграций схемы БД в 1.0.0 нет: откат на 0.6.0 возможен без восстановления базы.

6 Безопасность

Исправления по самооценке (подробно — отчёт самооценки, раздел «Найденные недостатки и исправления»): известный секрет подписи по умолчанию и приём токенов без сеанса; порт PostgreSQL на всех интерфейсах; лишние сведения в карточках коллег; перебор старого пароля при смене; уведомление о смене пароля; `X-Powered-By` и кэширование ответов с персональными данными; запись правил организации в журнал изменений вне транзакции; обращения за пределы контура при сборке и старте (Prisma, Scarf, npm, Swagger UI).

7 Известные ограничения

- Второй фактор входа — только через провайдера единого входа организации.
- Длина пароля по умолчанию — 8 символов; для соответствия OWASP ASVS уровня 1 организация задаёт 12.
- Две уязвимости зависимостей сервера (`deepmerge-ts` в утилите миграций, `uuid` в библиотеке выгрузок) не эксплуатируются в программе и будут закрыты обновлением зависимостей в 1.1.0.
- Даты в интерфейсе выводятся словами («14 мая 2027»), а не в формате ДД.ММ.ГГГГ из ТЗ; в форме Т-7 и в выгрузке графика (с 1.0.0 — значения дат Excel) — ДД.ММ.ГГГГ.